



中华人民共和国国家标准

GB/T 45279.3—2025

IPv4/IPv6 网络安全防护技术规范 第3部分：互联网数据中心

IPv4/IPv6 network security protection technical specification—
Part 3: Internet data center

2025-02-28 发布

2025-06-01 实施

国家市场监督管理总局 发布
国家标准化管理委员会

目 次

前言 III

引言 IV

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 2

5 IDC 总体要求 2

 5.1 IDC 安全防护范围 2

 5.2 IDC 安全防护内容 2

6 IDC 安全防护要求 3

 6.1 第 1 级要求 3

 6.2 第 2 级要求 4

 6.3 第 3 级要求 7

7 IDC 安全防护测试方法 9

 7.1 第 1 级要求 9

 7.2 第 2 级要求 15

 7.3 第 3 级要求 32

参考文献 44



前 言

本文件按照 GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

GB/T 45279《IPv4/IPv6 网络安全防护技术规范》与 GB/T 44810《IPv6 网络安全设备技术要求》共同构成支撑 IPv6 安全的国家标准体系。

本文件是 GB/T 45279《IPv4/IPv6 网络安全防护技术规范》的第3部分，GB/T 45279 已经发布了以下部分：

- 第1部分：IP 承载网；
- 第2部分：移动通信网；
- 第3部分：互联网数据中心；
- 第4部分：内容分发网络。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中华人民共和国工业和信息化部提出。

本文件由全国通信标准化技术委员会(SAC/TC 485)归口。

本文件起草单位：中国信息通信研究院、北京浩瀚深度信息技术股份有限公司、中国电信集团有限公司、北京天融信网络安全技术有限公司、国家计算机网络应急技术处理协调中心、北京国家金融科技认证中心有限公司、深圳大学、中兴通讯股份有限公司、北京通和实益电信科学技术研究所有限公司、新华三技术有限公司。

本文件主要起草人：戴方芳、贺倩、庞韶敏、宫盼盼、黄维龙、康和、寇增杰、王龔、周继华、李秀成、袁玉东、李红曼、王妍娟、江魁、万晓兰。

引 言

根据《关于加快推进互联网协议第六版（IPv6）规模部署和应用工作的通知》，为更好面对网络复杂化和用户规模扩大化带来的安全挑战，推动 IPv6 网络安全工作的标准化，我国制定了一系列 IPv6 安全标准。其中，GB/T 45279《IPv4/IPv6 网络安全防护技术规范》是为规范电信网和互联网重要网络单元在 IPv6 部署后所开展的安全防护工作，拟分为以下部分。

- 第 1 部分：IP 承载网。目的在于 IPv6 部署后，推动 IP 承载网的安全防护工作。
- 第 2 部分：移动通信网。目的在于 IPv6 部署后，推动移动通信网的安全防护工作。
- 第 3 部分：互联网数据中心。目的在于 IPv6 部署后，推动互联网数据中心的安全防护工作。
- 第 4 部分：内容分发网络。目的在于 IPv6 部署后，推动内容分发网络的安全防护工作。

IPv4/IPv6 网络安全防护技术规范

第 3 部分：互联网数据中心

1 范围

本文件规定了 IPv4、IPv6、双栈环境下互联网数据中心 (IDC) 安全防护要求和测试方法,包括业务安全、网络安全、主机安全、中间件安全、物理环境安全和管理安全等方面。
本文件适用于指导支持 IPv4/IPv6 协议的 IDC 安全防护工作开展和推进。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中,注日期的引用文件,仅该日期对应的版本适用于本文件;不注日期的引用文件,其最新版本(包括所有的修改单)适用于本文件。

GB/T 18018—2019	信息安全技术	路由器安全技术要求	
GB/T 21050—2019	信息安全技术	网络交换机安全技术要求	
GB/T 22239—2019	信息安全技术	网络安全等级保护基本要求	
GB/T 22240—2020	信息安全技术	网络安全等级保护定级指南	
GB/T 29240—2012	信息安全技术	终端计算机通用安全技术要求与测试评价方法	
GB/T 39680—2020	信息安全技术	服务器安全技术要求和测评准则	
GB/T 41267—2022	网络关键设备安全技术要求	交换机设备	
GB/T 41269—2022	网络关键设备安全技术要求	路由器设备	
YD/T 1478—2006	电信管理网安全技术要求		
YD/T 2698—2014	电信网和互联网安全防护基线配置要求及检测要求	网络设备	
YD/T 2700—2014	电信网和互联网安全防护基线配置要求及检测要求	数据库	
YD/T 2701—2014	电信网和互联网安全防护基线配置要求及检测要求	操作系统	
YD/T 2702—2014	电信网和互联网安全防护基线配置要求及检测要求	中间件	
YD/T 2703—2014	电信网和互联网安全防护基线配置要求及检测要求	Web 应用系统	
YD/T 3799—2020	电信网和互联网网络安全防护定级备案实施指南		

3 术语和定义

下列术语和定义适用于本文件。

3.1

IDC 服务 IDC services

拥有宽带出口,并以外包出租的方式为用户的服务器、网络设备等互联网相关设备提供放置、代理维护、系统配置及管理服务,或提供计算、存储、软件等资源的出租、通信线路和出口带宽的代理租用和其他应用服务的电子信息系统机房服务。

3.2

IDC 客户 customer of IDC

通过购买 IDC 服务以满足其业务需求的群体。

4 缩略语

下列缩略语适用于本文件。

ACL:访问控制列表(Access Control List)
ARP/ND:地址解析协议/邻居发现协议(Address Resolution Protocol/Neighbor Discovery Protocol)
CC:挑战黑洞(Challenge Collapsar)
CPU:中央处理器(Central Processing Unit)
DCN:数据中心网络(Data Center Network)
DDoS:分布式拒绝服务(Distributed Denial of Service)
FTP:文件传输协议(File Transfer Protocol)
HTTP:超文本传输安全协议(Hyper Text Transfer Protocol)
ICMP:互联网控制报文协议(Internet Control Message Protocol)
IDC:互联网数据中心(Internet Data Center)
IP:网际协议(Internet Protocol)
IPv4:互联网协议第四版(Internet Protocol version 4)
IPv6:互联网协议第六版(Internet Protocol version 6)
MAC:媒体接入控制层(Medium Access Control)
SNMP:简单网络管理协议(Simple Network Management Protocol)
SNMPv3:简单网络管理协议第三版(Simple Network Management Protocol version 3)
SQL:结构化查询语言(Structured Query Language)
SSH:安全协议外壳(Secure Shell)
TCP:传输层控制协议(Transmission Control Protocol)
Telnet:终端网络(Terminal Network)
TLCP:传输层加密协议(Transport Layer Cipher Protocol)
TLS:传输层安全协议(Transport Layer Security)
UDP:用户数据包协议(User Datagram Protocol)
URL:统一资源定位符(Uniform Resource Locator)
URPF:单播逆向路径转发(Unicast Reverse Path Forwarding)
USM:用户安全模型(User Security Model)
VACM:基于视图的访问控制模型(View-based Access Control Model)
VLAN:虚拟局域网(Virtual Local Area Network)
VPN:虚拟专用网(Virtual Private Network)

5 IDC 总体要求



5.1 IDC 安全防护范围

IDC 的安全防护范围包括为用户提供各种 IDC 服务的 IDC 基础设施(包括 IP 网络、主机、服务器、安全设备等)、为保证 IDC 正常运行所构建的 IDC 支撑系统(包括集中配置、集中监控、灾备等)和为保证 IDC 网络安全所构建的 IDC 网络安全防护系统。

5.2 IDC 安全防护内容

应按照 GB/T 22240—2020、YD/T 3799—2020 确定移动通信网符合的安全等级,并在遵循

GB/T 22239—2019 规定的相应安全等级安全通用要求基础上,按照本文件要求开展包括业务安全、网络安全、主机安全、中间件安全、物理环境安全和管理安全等六个层面的安全防护工作。本文件提出第 1 级至第 3 级要求,第 4 级、第 5 级要求暂同第 3 级要求)。其中:

- a) 业务安全:为实现 IDC 业务所使用的应用系统的安全,一般指采用应用层技术构建的业务系统、网管支撑系统涉及相关安全,如 Web 安全、FTP、SNMP 应用协议安全等。
- b) 网络安全:主要包括 IDC 的网络结构、网络管理、网络入侵防范、网络安全监测、网络设备防护等方面内容 and 要求。
- c) 主机安全:主要包括 IDC 通用主机设备安全等方面内容 and 要求。
- d) 中间件安全:主要包括 IDC 的中间件基本安全要求等方面内容 and 要求。
- e) 物理环境安全:主要包括 IDC 所在的物理环境的安全要求。
- f) 管理安全:主要包括 IDC 的安全管理、风险评估、应急预案等方面内容 and 要求。

6 IDC 安全防护要求

6.1 第 1 级要求

6.1.1 网络安全

6.1.1.1 网络结构

IDC 在生产运行、操作维护、系统管理等方面,应采用网络设备如交换机、路由器、防火墙等对其内部网络进行安全域划分,划分方式包括 VLAN 划分、IP 网段划分、可信任域划分等。

6.1.1.2 网络管理

IDC 网络管理应满足以下要求。

- a) 对 IDC 业务进行梳理,对客户源地址进行备案并做相应的控制。
- b) IDC 启用跨安全域访问控制策略,控制内容包括访问源的 MAC 地址、IPv4/IPv6 地址、端口号等信息。
- c) IDC 集中运维安全管控系统与为 IDC 提供服务的基础设施相隔离并部署在不同网络区域。
- d) IDC 集中运维安全管控系统的网络边界设备按不同业务需求配置相应的访问控制策略,只开放管理必需的服务及端口,避免开放较大的 IPv4/IPv6 地址段及服务。
- e) IDC 集中运维安全管控系统采用安全的管理和控制信息分发、过滤机制;网络管理信息加密传送;对目的地址为管理接口的非管理报文和目的地址为数据业务接口的管理报文进行控制。

6.1.1.3 网络入侵防范

IDC 面向互联网应具备相应防护能力,对进出 IDC 的所有数据流量进行防护。

6.1.1.4 网络安全监测

IDC 应能在互联网接口处进行流量监控分析,及时发现导致流量异常的安全事件。

6.1.1.5 网络设备防护

IDC 网络设备主要包括各类路由器、交换机设备等,应满足 GB/T 18018—2019、GB/T 21050—2019、GB/T 41267—2022、GB/T 41269—2022 等的要求。网络设备的安全基线配置应满足 YD/T 2698—2014 相关要求。

6.1.2 主机安全

IDC 通用主机设备主要包括各类通用服务器、工作站、终端、数据库等,应满足 GB/T 29240—2012、GB/T 39680—2020 等的要求。通用主机设备的操作系统安全基线配置应满足 YD/T 2701—2014 要求,数据库的安全基线配置应满足 YD/T 2700—2014 要求,Web 应用系统的安全基线配置应满足 YD/T 2703—2014 要求。

6.1.3 中间件安全

IDC 自身业务使用中间件的安全基线配置应满足 YD/T 2702—2014 的要求。

6.1.4 物理环境安全

应满足 GB/T 22239—2019 中第一级的安全物理环境要求。

6.1.5 管理安全

应满足 GB/T 22239—2019 中第一级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求。

6.2 第 2 级要求

6.2.1 业务安全

业务安全应满足以下要求:

- a) 按照合同提供 IDC 客户指定的安全防护资源和备份恢复技术能力;
- b) 保证 IDC 网络单元关键网络设备的业务处理能力具备冗余空间,满足业务高峰期需要;
- c) IDC 与互联网接口处的流量带宽具备冗余空间,满足业务高峰期需要。

6.2.2 网络安全

6.2.2.1 网络结构

除满足第 1 级的要求以外,还应满足以下要求:

- a) 绘制与当前运行情况相符的网络拓扑结构图(反映互联网接口、内部网络划分等内容);
- b) IDC 的网络结构根据网络的运营、管理或区域等因素在逻辑上合理的实现分层和分级,IDC 内部网络区域的划分与网络结构和组织形式保持一致。

6.2.2.2 网络管理

除满足第 1 级的要求以外,还应满足以下要求。

- a) 通过运营企业内部网络(如 DCN 网络)远程访问 IDC 中设备时,按业务需求在被访问的 IDC 网络边界设备上启用接入访问控制策略,对包括源 IPv4/IPv6 地址、端口号等在内的控制项进行限制,避免开放过长 IP 地址段及过多端口。
- b) 通过公共互联网远程访问 IDC 中设备时,使用 VPN 方式访问,并按业务需求在被访问的 IDC 网络边界设备上启用接入访问控制策略,对包括源及目的 IPv4/IPv6 地址、端口号等在内的控制项进行限制,避免开放过长 IPv4/IPv6 地址段及过多端口。
- c) IDC 网络边界的隔离设备和 IDC 集中运维安全管控系统如采用 Web 方式进行配置和管理,采用如下措施:
 - 1) 使用用户安全鉴别和认证措施,如支持 TLS/TLS-PSK 协议等;

- 2) 使用代码审计等措施检测和消除 Web 安全漏洞,如 Web 组件漏洞、SQL 注入攻击、跨站脚本攻击等;
- 3) 保证配置安全,采取隐蔽 Web 后台配置页面等措施,防止后台配置界面泄露、Web 路径泄露等漏洞被非法利用从而导致对设备的攻击入侵;
- 4) 限制 Web 服务器的访问和操作权限(避免 Web 访问非授权的敏感数据)。
- d) IDC 集中运维安全管控系统使用用户安全鉴别和认证措施,符合 YD/T 1478—2006 中相关安全技术要求,管理使用的 SNMP 协议支持 SNMPv3 并支持 VACM 和 USM 等安全机制,对于远程登录支持 SSH 以及相关加密和认证算法,对于 Web 管理应支持 TLS/TLCP 等安全协议。
- e) IDC 集中运维安全管控系统支持的 SNMP、SSH、FTP、HTTP、Telnet 等服务在非必要情况下关闭和禁用,使用 SNMP 协议的设备加强对 SNMP 写操作的管理控制,如采用增加 Community 的复杂度或是采用 ACL 控制等方式进行管理。
- f) IDC 集中运维安全管控系统能对节点、链路等各类资源的预警、告警、故障进行及时有效的定位,各类报警的阈值设置合理。
- g) IDC 集中运维安全管控系统具有并启用完整的系统安全日志功能。
- h) IDC 部署和启用虚假源地址流量控制策略,包括在 IDC 出口设备上开启单播逆向路径转发(URPF)功能,对于不具备开启条件的设备,启用访问控制列表(ACL)功能过滤虚假源地址。

6.2.2.3 网络入侵防范

除满足第 1 级的要求以外,还应满足以下要求。

- a) IDC 具有对网络安全漏洞攻击防范能力,包括以下能力:
 - 1) 能对已知安全漏洞攻击流量和攻击报文进行检测;
 - 2) 能对组合型攻击流量和攻击报文进行检测和告警;
 - 3) 能对攻击源进行溯源和记录操作行为;
 - 4) 能解析 IPv4/IPv6 报文,通过 IP 5 元组、攻击数据包类型、攻击报文关键字、攻击流量等对已知安全漏洞攻击进行阻断;
 - 5) 能对疑似安全漏洞攻击行为进行研判和预警。
- b) IDC 具备对 DDoS 攻击的防范能力,包括以下能力:
 - 1) 能对常见 DDoS 攻击(如 ARP/ND 泛洪攻击、同步泛洪攻击、UDP 泛洪攻击、ICMP 泛洪攻击等)进行检测和告警;
 - 2) 能对 Web 应用层 DDoS 攻击(如 CC 攻击)进行检测和告警;
 - 3) 能对 DDoS 攻击源或僵尸机记录攻击行为;
 - 4) 能通过解析 IPv4/IPv6 报文,基于 IP 5 元组、网络应用种类、协议类型、协议标签等进行包过滤、阈值限制、重定向等手段清洗 DDoS 攻击流量,DDoS 攻击防护能力覆盖 IDC 网络出口带宽。
- c) IDC 应能检测并防御以下攻击行为:端口扫描、暴力破解攻击、木马后门攻击、缓冲区溢出攻击、ARP/ND 欺骗攻击、IP 碎片攻击、网络蠕虫攻击等。

6.2.2.4 网络安全监测

除满足第 1 级的要求以外,还应满足以下要求:

- a) 对 IDC 自身业务中的重要主机进行监视,包括监视主机的 CPU、硬盘、内存、网络等资源的使用情况;
- b) 对于目的地址为 IDC 网络内地址的数据包,安全域边界具有有效的攻击识别和监测能力,具

有对于异常数据流量的识别和处理能力；

- c) IDC 出入口路由器具 IPv4/IPv6 源地址验证和虚假源地址流量过滤功能；
- d) IDC 出入口路由器具流量元数据采集和转发功能，采集格式支持 NetFlow(V5 及以上)、NetStream(V5 及以上)或 sFlow(V4 及以上)，采样率不低于千分之一。

6.2.2.5 网络保护与恢复

IDC 网络保护与恢复应满足以下要求：

- a) IDC 具备一定的抗灾难以及灾难恢复能力，自身重要服务器、重要部件、重要数据库应当采用本地双机备份的方式进行容灾保护；
- b) IDC 网络灾难恢复时间满足国家或行业对应急预案的相关要求；
- c) IDC 重要信息数据提供本地异机备份；
- d) IDC 的数据备份范围和时间间隔、数据恢复能力符合国家或行业对应急预案的相关要求。

6.2.2.6 网络设备防护

除满足第 1 级的要求以外，还应满足以下要求：

- a) IDC 网络宜配置中央日志服务器，对日志进行统一管理、分析处理；
- b) 对 IDC 网络系统中的关键网络设备运行状况、网络流量、用户行为等进行日志记录，并定期对日志进行安全审计，形成相关的审计文档；
- c) IDC 网络边界设备的安全日志在本地或外部设备上记录、输出、存储，并及时、定期审计安全域边界安全防护设备的日志，日志审计范围覆盖设备自身操作维护记录，以及设备对外部发起行为的记录，形成相关的审计文档；
- d) IDC 网络设备审计记录包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。

6.2.3 主机安全

与第 1 级的要求相同。

6.2.4 中间件安全

除满足第 1 级的要求以外，还应满足以下要求：

- a) IDC 自身业务所使用的中间件进行协议级的配置时禁用中间件的不必要的 HTTP 方法，例如 PUT, TRACE, DELETE 等，若启用了 HTTPS 则禁用 HTTP；
- b) IDC 自身业务所使用的中间件启用必要的语言安全设置，例如 PHP 语言安全设置，JAVA 语言安全设置。

6.2.5 物理环境安全

应满足第 1 级和 GB/T 22239—2019 中第二级的安全物理环境要求。

6.2.6 管理安全

6.2.6.1 安全管理要求

除满足 GB/T 22239—2019 中第二级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求外，还应满足如下要求：

- a) IDC 有介质存取、验证、转存、销毁管理制度，确保备份数据授权访问；

- b) IDC 按介质特性对备份数据进行定期的有效性验证；
- c) IDC 有相关服务器设备的灾难备份及恢复的管理制度。

6.2.6.2 风险评估要求

IDC 风险评估应满足以下要求：

- a) IDC 及其所属各类设备、系统根据安全防护相关规定定期进行安全风险评估（至少每两年一次），风险评估范围与 IDC 安全防护范围一致；
- b) IDC 安全风险评估至少覆盖业务安全、网络安全、主机安全、中间件安全、物理环境安全等相关技术风险和人员安全、运维安全等相关管理风险，至少包含 IDC 相关资产、脆弱性、威胁、安全措施、风险分析等要素和内容，并根据评估结果制定相应的风险处理计划。

6.2.6.3 灾难恢复预案

IDC 灾难恢复预案应满足以下要求：

- a) IDC 制定完整的灾难恢复预案及对应管理制度；
- b) IDC 有灾难恢复预案的教育和培训（至少每半年一次），相关人员了解灾难恢复预案并具有对灾难恢复预案进行实际操作的能力；
- c) IDC 有灾难恢复预案的演练（至少每年一次），并根据演练结果对灾难恢复预案进行修正。

6.3 第 3 级要求

6.3.1 业务安全

与第 2 级的要求相同。

6.3.2 网络安全

6.3.2.1 网络结构

除满足第 2 级的要求以外，IDC 的 Web 服务器、后台数据库应分开部署在不同物理主机上。

6.3.2.2 网络管理

除满足第 2 级的要求之外，安全域之间的 IP 网络边界设备应启用接入访问控制策略，应依据不同安全域互相访问需求对包括源 IP 地址、端口号等在内的控制项进行限制，避免开放过长 IP 地址段及过多端口。

6.3.2.3 网络入侵防范

除满足第 2 级的要求之外，还应满足以下要求：

- a) 当检测到攻击行为时，记录攻击源 IP、攻击类型、攻击目的、攻击时间，在发生严重入侵事件时应能够实时报警；
- b) 在 IDC 网络边界处对恶意代码进行检测和处理，并及时对检测系统进行更新；
- c) IDC 对防恶意代码软件进行统一管理。

6.3.2.4 网络安全监测

除满足第 2 级的要求外，还应满足以下要求。

- a) IDC 具有对僵尸网络、木马和蠕虫的监测能力，在 IDC 出入口对进出流量进行监测，在 IDC 内部对内部流量进行监测。包括以下能力：

- 1) 能对已知僵尸网络、木马和蠕虫病毒进行监测和告警；
 - 2) 能对压缩流量和嵌入型僵尸网络和木马进行监测和告警；
 - 3) 能对僵尸网络和木马控制端进行溯源并记录操作行为；
 - 4) 能对疑似僵尸网络、木马和蠕虫病毒进行预警；
 - 5) 能对 IDC 机房服务器的 Web 网站进行挂马扫描；
 - 6) 能对 IDC 机房服务器的 IPv4/IPv6 地址进行系统漏洞扫描；
 - 7) 具备基于网络行为、样本特征和恶意 URL 的僵尸网络、木马和蠕虫病毒库。
- b) IDC 具有对不同种类业务相关数据进行监测、统计、控制、过滤的功能。
- c) 对 IDC 管理运维人员的设备系统访问等操作行为进行监控和审计。

6.3.2.5 网络保护与恢复

除满足第 2 级的要求外,还满足以下要求:

- a) IDC 应具备一定的抗灾难以及灾难恢复能力,重要服务器、重要部件、重要数据库应当采用异址(同城不同地点的机房或异地)方式进行容灾保护;
- b) IDC 与互联网之间应具备冗余链路;
- c) IDC 网络中关键设备之间应当提供多条物理链路(如 Web 服务器设备与数据库服务器设备之间);
- d) IDC 重要信息数据应提供异址备份(同城不同地点的机房或异地)。

6.3.2.6 网络设备防护

除满足第 2 级的要求之外,IDC 网络设备账号口令更新周期应不大于 60 d。

6.3.3 主机安全

除满足第 2 级的要求之外,还应满足以下要求:

- a) IDC 通用主机操作系统和数据库系统管理用户口令更新周期不大于 60 d;
- b) 依据安全策略严格控制用户对有敏感标记重要信息(如,配置信息、审计记录等)的操作;
- c) 能够根据记录数据进行分析,并生成审计报表;
- d) 保护审计进程,避免受到未预期的中断;
- e) 能够检测到对 IDC 内主机进行入侵的行为,能够记录入侵的源 IPv4/IPv6 地址、攻击的类型、攻击的目的、攻击的时间,并在发生严重入侵事件时提供报警。

6.3.4 中间件安全

除满足第 2 级的要求以外,IDC 自身业务所使用的中间件应用运行时应启动必要的自我安全保护技术。

6.3.5 物理环境安全

应满足第 2 级和 GB/T 22239—2019 中第三级的安全物理环境要求。

6.3.6 管理安全

6.3.6.1 安全管理要求

应满足第 2 级和 GB/T 22239—2019 中第三级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求。

6.3.6.2 风险评估要求

除满足第 2 级要求外,还应定期对 IDC 及其所属各类设备、系统进行安全风险评估(至少每年一次)。

6.3.6.3 灾难恢复预案

除满足第 2 级要求外,还应定期组织 IDC 及其所属各类设备、系统灾难恢复预案的教育培训(至少每季度一次)和演练(至少每半年一次)。

6.3.6.4 安全建设管理

IDC 业务实施时,客户应提交业务客户信息采集表,主要包含以下信息:系统数据分类与安全等级、系统对基础设施的依赖关系、系统要求配置的防火墙与路由器策略等。

6.3.6.5 安全运维管理

IDC 安全运维应满足以下要求:

- a) 至少每六个月检查一次防火墙和路由器的规则设置(检测防火墙和路由器是否存在冲突规则、冗余规则或无效规则等);
- b) 至少每三个月进行一次应用层弱点扫描,当基础设施或应用完成重大的升级或调整后,执行应用层弱点扫描;
- c) 至少每年进行一次应用层渗透测试,当基础设施或应用完成重大的升级或调整后,执行应用层渗透测试。

7 IDC 安全防护测试方法

7.1 第 1 级要求

7.1.1 网络安全

7.1.1.1 网络结构

第 1 级网络结构的测试方法见表 1。

表 1 网络结构安全域划分测试方法

测试编号:IDC-第 1 级-网络安全-网络结构安全-01
测试项目:6.1.2.1 IDC 在生产运行、操作维护、系统管理等方面,应采用网络设备如交换机、路由器、防火墙等对其内部网络进行安全域划分,划分方式包括 VLAN 划分、IP 网段划分、可信任域划分等
测试步骤: 1) 访谈网络运维和安全管理人員,查看网络设计/验收文档、网络拓补文档、网络安全策略、运维管理制度、设备配置文档等; 2) 进入现场检查网络及设备实际组网情况,实地查看 IDC 的拓补、设备部署、链路设置等情况; 3) 分别检查不同的安全域的网络管理情况,检查其是否满足分域定制的管理要求
预期结果: IDC 实际拓补结构、设备部署等均完成了安全域划分
判定原则: 达到以上预期结果,则通过,否则不通过

7.1.1.2 网络管理

第 1 级网络管理的测试方法见表 2～表 6。

表 2 网络管理源地址备案测试方法

测试编号:IDC-第 1 级-网络安全-网络管理安全-01
测试项目:6.1.2.2 a)对 IDC 业务进行梳理,对客户源地址进行备案并做相应的控制
测试步骤: 1) 访谈 IDC 运维人员,查看客户源地址规划和备案记录; 2) 检查并核对网络设备实际配置地址情况
预期结果: 1) IDC 客户源地址分配和使用有统一规划和备案,并有相应的控制; 2) IDC 客户源地址备案信息与实际部署一致
判定原则: 达到以上预期结果,则通过,否则不通过

表 3 网络管理访问控制策略测试方法

测试编号:IDC-第 1 级-网络安全-网络管理安全-02
测试项目:6.1.2.2 b)IDC 启用跨安全域访问控制策略,控制内容包括访问源的 MAC 地址、IPv4/IPv6 地址、端口号等信息
测试步骤: 1) 访谈网络运维和安全管理人员,查看网络设计文档、网络安全策略、运维管理制度、设备配置文档等,查看 IDC 跨域访问控制策略; 2) 使用流量发生器构造具有不同源 MAC、源 IPv4/IPv6 地址、端口号特征的报文流访问不同安全域; 3) 在安全域边界设备处查看访问日志,在安全域内被访问设备处使用流量分析仪进行抓包分析
预期结果: 1) IDC 启用了跨安全域访问控制策略; 2) IDC 内不同安全域能够对非法访问请求进行拦截阻断和记录
判定原则: 达到以上预期结果,则通过,否则不通过

表 4 网络管理隔离部署测试方法

测试编号:IDC-第 1 级-网络安全-网络管理安全-03
测试项目:6.1.2.2 c)IDC 集中运维安全管控系统与为 IDC 提供服务的基础设施相隔离并部署在不同网络区域
测试步骤: 1) 访谈网络运维和安全管理人员,查看网络设计文档、网络安全策略、运维管理制度、设备配置文档等,查看 IDC 业务网络与运维安全管控系统间的连接情况; 2) 从 IDC 业务网络侧访问运维安全管控系统中的设备,验证网络与运维安全管控系统间是否实现逻辑隔离,评估安全域访问控制策略的应用效果; 3) 使用网络维护终端访问运维安全管控系统中的设备,验证是否有安全的访问认证措施对其进行限制

预期结果： 1) IDC 运维安全管控系统与提供服务基础设施间采用了逻辑隔离的隔离措施； 2) 网络维护终端访问被管理网络设备时采取了安全措施
判定原则： 达到以上预期结果，则通过，否则不通过

表 5 网络管理网络边界测试方法

测试编号:IDC-第 1 级-网络安全-网络管理安全-04
测试项目:6.1.2.2 d)IDC 集中运维安全管控系统的网络边界设备按不同业务需求配置相应的访问控制策略,只开放管理必须的服务及端口,避免开放较大的 IPv4/IPv6 地址段及服务
测试步骤： 1) 访谈网络运维和安全管理人员,查看网络安全策略、设备配置文档等,查看 IDC 运维安全管控系统的网络边界设备访问控制策略； 2) 对 IDC 运维安全管控系统进行 IP 地址和端口扫描,查看扫描结果
预期结果： 1) IDC 集中运维安全管控系统的网络边界设备配置了访问控制策略； 2) IDC 集中运维安全管控系统只开放了有限但必需的 IP 地址和端口服务
判定原则： 达到以上预期结果，则通过，否则不通过

表 6 网络管理信息分发过滤测试方法

测试编号:IDC-第 1 级-网络安全-网络管理安全-05
测试项目:6.1.2.2 e)IDC 集中运维安全管控系统采用安全的管理和控制信息分发、过滤机制;网络管理信息加密传送;对目的地址为管理接口的非管理报文和目的地址为数据业务接口的管理报文进行控制
测试步骤： 1) 访谈网络运维人员,查看运维安全管控系统设计文档、网络安全策略、设备管理配置记录等,查看 IDC 集中运维安全管控系统的管理信息控制机制； 2) 检查是否配备相应设备或进行有关配置,实现管理、控制信息能够安全的分发和过滤； 3) 使用流量分析仪抓取管理报文,验证网络管理信息是否通过加密方式传送； 4) 检查集中运维安全管控系统设备是否设置专用管理接口； 5) 将被测设备的管理接口作为目的地址发送非管理报文,检查管理接口针对非管理报文的处理情况； 6) 将被测设备的业务接口作为目的地址发送管理报文,检查业务接口针对管理报文的处理情况
预期结果： 1) IDC 集中运维安全管控系统的网络管理采用了管理信息和控制信息的安全分发、过滤等机制； 2) IDC 集中运维安全管控系统的网络流量管理策略为 IDC 相关管理信息流提供较高的优先级； 3) IDC 集中运维安全管控系统网络管理会话信息通过加密方式传送； 4) IDC 集中运维安全管控系统相关网络设备均划分专用的管理接口； 5) IDC 集中运维安全管控系统相关设备的专用管理接口能对目的地址为设备本身的非管理报文进行严格过滤和控制； 6) IDC 集中运维安全管控系统相关设备的专用管理接口能对目的地址为业务接口的管理报文进行严格过滤和控制
判定原则： 达到以上预期结果，则通过，否则不通过

7.1.1.3 网络入侵防范

第 1 级网络入侵防范的测试方法见表 7。

表 7 网络入侵防范数据流量测试方法

测试编号:IDC-第 1 级-网络安全-网络入侵防范-01
测试项目:6.1.2.3 IDC 面向互联网应具备相应防护能力,对进出 IDC 的所有数据流量进行防护
测试步骤: 1) 访谈安全管理人员,查看网络拓扑文档、网络安全策略等,查看 IDC 安全防护设备的部署; 2) 查看 IDC 安全防护设备的策略配置和使用日志
预期结果: IDC 配备有基本的安全防护设备,具有面向互联网的基本防护能力。所有安全防护设备功能均符合相应的设备技术要求和设备安全技术要求
判定原则: 达到以上预期结果,则通过,否则不通过

7.1.1.4 网络安全监测

第 1 级网络安全监测的测试方法见表 8。

表 8 网络安全监测流量监控测试方法

测试编号:IDC-第 1 级-网络安全-网络安全监测-01
测试项目:6.1.2.4 IDC 应能在互联网接口处进行流量监控分析,及时发现导致流量异常的安全事件
测试步骤: 1) 访谈安全管理人员,查看网络拓扑文档、网络安全策略、设备配置文档等,查看 IDC 与互联网边界处的监测能力部署; 2) 在互联网和 IDC 之间双向发送特定流量; 3) 在 IDC 内部测试位置接入流量分析仪,将流量采集分析结果与发送流量进行比对; 4) 查看 IDC 与互联网接口处的流量分析结果,与发送流量进行比对
预期结果: 1) IDC 在互联网接口处部署有流量监测能力; 2) IDC 流量监测系统能够及时发现导致流量异常的安全事件
判定原则: 达到以上预期结果,则通过,否则不通过

7.1.1.5 网络设备防护

第 1 级网络设备防护的测试方法见表 9。

表 9 网络设备防护达标测试方法

测试编号:IDC-第 1 级-网络安全-网络设备防护-01
测试项目:6.1.2.5 IDC 网络设备主要包括各类路由器、交换机设备等,应满足相应标准如 GB/T 18018—2019、GB/T 21050—2019、GB/T 41267—2022、GB/T 41269—2022 等要求。网络设备的安全基线配置应满足 YD/T 2698—2014 相关要求
测试步骤: 1) 访谈设备采购管理、运维和安全管理人員,查看设备入网检测报告、设备入网证等; 2) 检查 IDC 相关数据网络设备的技术规范和安全配置
预期结果: 1) IDC 涉及的所有网络设备(如以太网交换机、具有路由功能的交换机、低端路由器、高端路由器等设备)均有有效的设备入网证,均可支持 IPv4/IPv6 协议; 2) IDC 涉及的所有网络设备相关功能均符合相应的设备技术要求和设备安全技术要求; 3) IDC 涉及的所有网络设备安全基线配置符合相应的基线要求
判定原则: 达到以上预期结果,则通过,否则不通过

7.1.2 主机安全

第 1 级主机安全的测试方法见表 10。

表 10 主机安全通用测试方法

测试编号:IDC-第 1 级-主机安全-01
测试项目:6.1.3 IDC 通用主机设备主要包括各类通用服务器、工作站、终端、数据库等,应满足相应标准如 GB/T 29240—2012、GB/T 39680—2020 等要求。通用主机设备的操作系统安全基线配置应满足 YD/T 2701—2014 要求,数据库的安全基线配置应满足 YD/T 2700—2014 要求,Web 应用系统的安全基线配置应满足 YD/T 2703—2014 要求
测试步骤: 1) 访谈设备采购管理、运维和安全管理人員,查看设备安全检测报告等; 2) 检查 IDC 现网使用的通用主机设备的技术规范和安全配置
预期结果: IDC 现网使用的通用主机设备相关功能均符合相应的设备技术要求和设备安全技术要求
判定原则: 达到以上预期结果,则通过,否则不通过

7.1.3 中间件安全

第 1 级中间件安全的测试方法见表 11。

表 11 中间件安全基线测试方法

测试编号:IDC-第 1 级-中间件安全-01
测试项目:6.1.4 IDC 自身业务使用中间件的安全基线配置应满足 YD/T 2702—2014 要求
测试步骤: 1) 访谈设备运维和安全管理人员,查看中间件安全检测报告等; 2) 检查 IDC 现网使用的通用主机设备中间件的技术规范和安全配置
预期结果: IDC 现网使用的通用主机中间件相关功能均符合相应的技术要求和安全要求
判定原则: 达到以上预期结果,则通过,否则不通过

7.1.4 物理环境安全

第 1 级物理环境安全的测试方法见表 12。

表 12 物理环境安全 1 级测试方法

测试编号:IDC-第 1 级-物理环境安全-01
测试项目:6.1.5 应满足 GB/T 22239—2019 中第一级的安全物理环境要求
测试步骤: 1) 访谈物理环境管理人员,查看物理环境设计文档、管理制度、维护记录等,查看其是否符合 GB/T 22239—2019 中第一级的相关要求; 2) 现场检查 IDC 所处的物理环境
预期结果: IDC 物理环境的安全要求符合 GB/T 22239—2019 中第一级的相关要求
判定原则: 达到以上预期结果,则通过,否则不通过

7.1.5 管理安全

第 1 级管理安全的测试方法见表 13。

表 13 管理安全 1 级测试方法

测试编号:IDC-第 1 级-管理安全-01
测试项目:6.1.6 应满足 GB/T 22239—2019 中第一级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求
测试步骤: 访谈网络安全管理人员,查看与网络安全管理相关的材料等,查看其是否符合 GB/T 22239—2019 中第一级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求

预期结果： IDC 管理安全要求符合 GB/T 22239—2019 中第一级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求
判定原则： 达到以上预期结果，则通过，否则不通过

7.2 第 2 级要求

7.2.1 业务安全

第 2 级业务安全的测试方法见表 14～表 16。

表 14 业务安全技术能力测试方法

测试编号：IDC-第 2 级-业务安全- 01
测试项目：6.2.1 a) 按照合同提供 IDC 客户指定的安全防护资源和备份恢复技术能力
测试步骤： 1) 访谈网络运维人员和安全管理人员，查看 IDC 与客户签订的安全保障合同、网络安全设备配置文档、运维管理制度、安全事件记录等，查看 IDC 根据客户需求实地部署的安全防护能力； 2) 使用流量发生器和模拟攻击工具分别从互联网和 IDC 内部网络向被测 IDC 客户发起特定模拟攻击； 3) 在 IDC 被测客户端和 IDC 安全防护系统及设备处查看模拟攻击效果和防护效果
预期结果： 1) IDC 按照合同要求向客户业务提供了有效的安全防护； 2) IDC 安全防护系统能够发现并阻断针对特定客户业务的攻击
判定原则： 达到以上预期结果，则通过，否则不通过

表 15 业务安全业务能力冗余测试方法

测试编号：IDC-第 2 级-业务安全- 02
测试项目：6.2.1 b) 保证 IDC 网络单元关键网络设备的业务处理能力具备冗余空间，满足业务高峰期需要
测试步骤： 1) 访谈网络运维人员，查看网络设备配置文档、故障告警记录等，查看 IDC 重要设备和部件的冗余情况； 2) 在日常业务高峰期查看关键设备的性能状况和运行状态
预期结果： 1) IDC 关键网络设备的业务处理能力具备冗余空间； 2) IDC 的冗余处理能力满足业务高峰期需要
判定原则： 达到以上预期结果，则通过，否则不通过

表 16 业务安全流量带宽冗余测试方法

测试编号:IDC-第 2 级-业务安全- 03
测试项目:6.2.1 c)IDC 与互联网接口处的流量带宽具备冗余空间,满足业务高峰期需要
测试步骤: 1) 访谈网络运维人员,查看网络设备配置文档、故障告警记录等,查看 IDC 互联网出口带宽的冗余情况; 2) 在日常业务高峰期查看 IDC 出口网络流量监测状态
预期结果: 1) IDC 与互联网间的接口带宽具备冗余空间; 2) IDC 与互联网间的接口带宽满足业务高峰期需要
判定原则: 达到以上预期结果,则通过,否则不通过

7.2.2 网络安全

7.2.2.1 网络结构安全

第 2 级网络结构安全除按照 7.1.1.1 的测试方法进行测试之外,还应按表 17~表 18 进行测试。

表 17 网络结构拓扑图测试方法

测试编号:IDC-第 2 级-网络安全-网络结构安全-01
测试项目:6.2.2.1 a)绘制与当前运行情况相符的网络拓扑结构图(反映互联网接口、内部网络划分等内容)
测试步骤: 1) 访谈网络运维和安全管理人員,查看网络拓扑文档; 2) 检查和验证网络拓扑记录信息是否与当前网络节点、链路等资源配置和运营情况相一致
预期结果: 1) 绘制有网络拓扑图(或记录完整拓扑信息的运维文档),且相关信息标注完整、准确; 2) 网络拓扑图(或记录完整拓扑信息的运维文档)及相关信息与当前网络节点、链路等资源配置和运营情况相符合
判定原则: 达到以上预期结果,则通过,否则不通过

表 18 网络结构分层分级测试方法

测试编号:IDC-第 2 级-网络安全-网络结构安全-02
测试项目:6.2.2.1 b)IDC 的网络结构根据网络的运营、管理或区域等因素在逻辑上合理的实现分层和分级,IDC 内部网络区域的划分与网络结构和组织形式保持一致



测试步骤： 1) 访谈网络运维和安全管理人员，查看网络设计文档、设备运维记录等，查看 IDC 内部网的层级设计和网络划分方式； 2) 检查网络及设备实际组网情况是否与设计相一致； 3) 检查 IDC 网络设备配置信息是否对内部网络进行了严格界定
预期结果： 1) IDC 的网络结构根据网络运营、管理或区域等因素在逻辑上进行实现分层和分级； 2) IDC 内部网络划分与网络结构和组织形式一致
判定原则： 达到以上预期结果，则通过，否则不通过

7.2.2.2 网络管理安全

第 2 级网络管理安全除按照 7.1.1.2 的测试方法进行测试之外，还应按照表 19～表 26 进行测试。

表 19 网络管理远程访问测试方法

测试编号：IDC-第 2 级-网络安全-网络管理安全-01
测试项目：6.2.2.2 a)通过运营企业内部网络(如 DCN 网络)远程访问 IDC 中设备时，按业务需求在被访问的 IDC 网络边界设备上启用接入访问控制策略，对包括源 IPv4/IPv6 地址、端口号等在内的控制项进行限制，避免开放过长 IP 地址段及过多端口
测试步骤： 1) 访谈网络运维和安全管理人员，查看网络设计文档、网络安全策略、运维管理制度、设备配置文档等，查看 IDC 内部网络与运营企业内部网络之间边界处的访问控制策略； 2) 构造具有不同源 IPv4/IPv6 地址、端口号特征的报文流从运营企业内部网络访问 IDC 内部不同网络； 3) 在 IDC 与运营企业内部网络的边界设备处查看访问日志，在 IDC 内被访问设备处使用流量分析仪进行抓包分析； 4) 对 IDC 内部系统进行 IP 地址和端口扫描，查看扫描结果
预期结果： 1) IDC 内部网络在和运营企业内部网络之间的边界处启用了访问控制策略； 2) IDC 内部网络和运营企业内部网络之间的边界处能够对非法访问请求进行拦截阻断和记录； 3) IDC 内部网络只开放了有限但必需的 IP 地址和端口服务
判定原则： 达到以上预期结果，则通过，否则不通过

表 20 网络管理 VPN 访问测试方法

测试编号：IDC-第 2 级-网络安全-网络管理安全-02
测试项目：6.2.2.2 b)通过公共互联网远程访问 IDC 中设备时，使用 VPN 方式访问，并按业务需求在被访问的 IDC 网络边界设备上启用接入访问控制策略，对包括源及目的 IPv4/IPv6 地址、端口号等在内的控制项进行限制，避免开放过长 IPv4/IPv6 地址段及过多端口

测试步骤： 1) 访谈网络运维和安全管理人员，查看网络设计文档、网络安全策略、运维管理制度、设备配置文档等，查看 IDC 内部网络与公共互联网之间边界处的访问控制策略； 2) 构造具有不同源 IP、端口号特征的报文流从公共互联网访问 IDC 内部不同网络； 3) 在 IDC 与公共互联网的边界设备处查看访问日志，在 IDC 内被访问设备处使用流量分析仪进行抓包分析； 4) 对 IDC 内部系统进行 IP 地址和端口扫描，查看扫描结果
预期结果： 1) IDC 内部网络在和公共互联网之间的边界处启用了 VPN 和访问控制策略； 2) IDC 内部网络和公共互联网之间的边界处能够对非法访问请求进行拦截阻断和记录； 3) IDC 内部网络只开放了有限但必需的 IP 地址和端口服务
判定原则： 达到以上预期结果，则通过，否则不通过

表 21 网络管理安全措施测试方法

测试编号:IDC-第 2 级-网络安全-网络管理安全-03
测试项目:6.2.2.2 c)IDC 网络边界的隔离设备和 IDC 集中运维安全管控系统如采用 Web 方式进行配置和管理，应采用如下措施:1)使用用户安全鉴别和认证措施，如支持 TLS/TLCP 协议等;2)使用代码审计等措施检测和消除 Web 安全漏洞，如 Web 组件漏洞、SQL 注入攻击、跨站脚本攻击等;3)保证配置安全，采取隐蔽 Web 后台配置页面等措施，防止后台配置界面泄露、Web 路径泄露等漏洞被非法利用从而导致对设备的攻击入侵;4)限制 Web 服务器的访问和操作权限(避免 Web 访问非授权的敏感数据)
测试步骤： 1) 访谈安全管理人员，查看边界隔离设备配置文档等，查看边界隔离设备 Web 页面和后台配置策略； 2) 使用维护终端访问边界隔离设备，通过流量分析仪对访问流量进行抓包和协议分析； 3) 使用漏洞扫描器对隔离设备 Web 系统进行扫描； 4) 检查 Web 后台管理路径，检查 Web 管理地址的允许访问地址列表； 5) 检查 Web 服务器的访问和操作权限
预期结果： 1) IDC 内 Web 管理界面启用了基本的用户名和口令认证，口令满足中相关要求； 2) IDC 内 Web 管理界面启用了 TLS/TLCP 等鉴别和认证措施； 3) IDC 内 Web 管理界面没有 Web 组件漏洞、SQL 注入攻击、跨站脚本攻击等可利用的漏洞； 4) IDC 内 Web 管理界面后台管理路径不使用默认或常见路径，对访问地址进行了限制； 5) IDC 内 Web 管理界面无访问非授权的敏感数据情况
判定原则： 达到以上预期结果，则通过，否则不通过

表 22 网络管理算法协议测试方法

测试编号:IDC-第 2 级-网络安全-网络管理安全-04
测试项目:6.2.2.2 d)IDC 集中运维安全管控系统使用用户安全鉴别和认证措施,符合 YD/T 1478—2006 中相关安全技术要求,管理使用的 SNMP 协议支持 SNMPv3 并支持 VACM 和 USM 等安全机制,对于远程登录支持 SSH 以及相关加密和认证算法,对于 Web 管理支持 TLS/TLCP 等安全协议
测试步骤: 1) 访谈网络运维和安全管理人员,查看网管系统设计文档、网络安全策略、设备配置记录、告警记录、日志文件资料等,查看 IDC 集中运维安全管控系统网络管理使用的安全机制; 2) 使用流量分析仪对网络管理报文进行抓包,分析其使用的网管协议是否满足要求,若采用 SNMP 协议应支持 SNMPv3; 3) 使用流量分析仪对远程登录发送的报文进行抓包,分析其加密和认证情况是否满足要求,如是否支持并采用 SSH; 4) 使用流量分析仪对访问 Web 页面发送的报文进行抓包,分析其使用的协议是否满足要求,如是否支持并采用 TLS/TLCP
预期结果: 1) IDC 集中运维安全管控系统的安全鉴别和认证措施符合 YD/T 1478—2006 中相关要求; 2) IDC 网络管理若采用 SNMP 协议,则支持 SNMPv3 协议,支持 VACM 和 USM 安全机制; 3) 对于远程登录管理方式,支持并采用安全加密协议(如 SSH 等); 4) 对于 Web 管理方式,支持并采用 TLS/TLCP 等安全协议
判定原则: 达到以上预期结果,则通过,否则不通过

表 23 网络管理服务安全测试方法

测试编号:IDC-第 2 级-网络安全-网络管理安全-05
测试项目:6.2.2.2 e)IDC 集中运维安全管控系统支持的 SNMP、SSH、FTP、HTTP、Telnet 等服务在非必要情况下关闭和禁用,必须使用 SNMP 协议的设备加强对 SNMP 写操作的管理控制,如采用增加 Community 的复杂度或是采用 ACL 控制等方式进行管理
测试步骤: 1) 访谈网络运维和安全管理人员,查看网管系统设计文档、网络安全策略、设备配置记录、告警记录、日志文件资料等,查看 IDC 集中运维安全管控系统网络管理使用的安全机制; 2) 对 IDC 集中运维安全管控系统的 SNMP、SSH、FTP、HTTP、Telnet 等远程管理服务功能尝试关闭和禁用,检查其是否具备在必要情况下关闭和禁用管理功能的能力; 3) 使用非授权用户通过缺省的 Community String 对 MIB 对象进行写操作; 4) 使用流量发生器构造不同源 IP 地址报文,通过 SNMP 端口实现 SNMP 写操作
预期结果: 1) IDC 集中运维安全管控系统具备在必要情况下关闭和禁用 SNMP 服务、远程登录管理等服务的功能; 2) IDC 使用 SNMP 进行网络管理时,修改了缺省 Community String 并增加了复杂度; 3) IDC 对 SNMP 使用用户进行了 ACL 等访问控制
判定原则: 达到以上预期结果,则通过,否则不通过

表 24 网络管理报警测试方法

测试编号:IDC-第 2 级-网络安全-网络管理安全-06
测试项目:6.2.2.2 f)IDC 集中运维安全管控系统能对节点、链路等各类资源的预警、告警、故障进行及时有效的定位,各类报警的阈值应设置合理
测试步骤: 1) 访谈网络运维和安全管理人员,查看网络管理系统设计文档、网络安全策略、设备配置记录、故障告警记录、日志和审计文档等,查看网络预警机制; 2) 检查 IDC 集中运维安全管控系统对各类资源的预警阈值是否合理
预期结果: 1) IDC 集中运维安全管控系统具有对节点和链路等各类资源的预警、告警、故障定位的相关功能; 2) IDC 集中运维安全管控系统对节点和链路等各类资源的预警、告警阈值设置合理
判定原则: 达到以上预期结果,则通过,否则不通过



表 25 网络管理日志功能测试方法

测试编号:IDC-第 2 级-网络安全-网络管理安全-07
测试项目:6.2.2.2 g)IDC 集中运维安全管控系统具有并启用完整的系统安全日志功能
测试步骤: 1) 访谈网络安全管理人员,查看网络安全策略、设备维护记录、日志记录、审计文件资料等,查看集中运维安全管控系统安全日志和审计相关功能; 2) 检查 IDC 集中运维安全管控系统是否均启用安全日志的功能
预期结果: 1) IDC 集中运维安全管控系统具有并启用了安全日志功能; 2) 安全日志能完整记录安全相关事件的来源、时间、事件描述等要素信息和内容; 3) 日志记录覆盖了维护、管理用户相关登录访问类事件、操作维护类事件,覆盖了设备相关状态监测、统计类事件、故障告警类事件
判定原则: 达到以上预期结果,则通过,否则不通过

表 26 网络管理虚假源地址测试方法

测试编号:IDC-第 2 级-网络安全-网络管理安全-08
测试项目:6.2.2.2 h)IDC 部署和启用虚假源地址流量控制策略,包括在 IDC 出口设备上开启单播逆向路径转发(URPF)功能,对于不具备开启条件的设备,启用访问控制列表(ACL)功能过滤虚假源地址

测试步骤：

- 1) 访谈网络运维人员,查看网络设计文档、网络安全策略、设备配置记录等,查看 IDC 出口路由设备的虚假源地址过滤策略；
- 2) 使用流量发生器构造多种虚假源地址报文从 IDC 内部网络向位于互联网中的靶机发送；
- 3) 在互联网靶机一侧查看虚假源地址报文的接收情况；
- 4) 统计虚假源地址报文过滤情况并与 IDC 出口网络设备的策略配置做比对

预期结果：

- 1) IDC 部署并启用了虚假源地址流量控制策略；
- 2) IDC 若启用 URPF 策略,则松散或严格 URPF 过滤效果均与预期一致；
- 3) IDC 若启用 ACL 策略,则过滤效果与预期一致

判定原则：

达到以上预期结果,则通过,否则不通过。

7.2.2.3 网络入侵防范

第 2 级网络入侵防范除按照 7.1.1.3 的测试方法进行测试之外,还应按照表 27～表 29 进行测试。

表 27 网络入侵防范漏洞防范测试方法

测试编号:IDC-第 2 级-网络安全-网络入侵防范-01
测试项目:6.2.2.3 a)IDC 具有对网络安全漏洞攻击防范能力,包括以下能力:1)能够对已知安全漏洞攻击流量和攻击报文进行检测;2)能够对组合型攻击流量和攻击报文进行检测和告警;3)能够对攻击源进行溯源和记录操作行为;4)能够解析 IPv4/IPv6 报文,通过 IP 5 元组、攻击数据包类型、攻击报文关键字、攻击流量等对已知安全漏洞攻击进行阻断;5)能够对疑似安全漏洞攻击行为进行研判和预警
测试步骤： 1) 访谈网络安全管理人员,查看网络安全策略、设备配置记录、漏洞扫描记录、风险评估报告等,查看 IDC 相关安全防护设备的策略配置和历史事件记录； 2) 使用流量发生器和模拟攻击工具构造多种流量和报文,通过利用已知安全漏洞对 IDC 内部网络靶机进行模拟攻击； 3) 使用流量发生器和模拟攻击工具构造多种流量和报文,通过利用非官方发布的、没有漏洞编号(如 CVE 编号)的疑似安全漏洞对 IDC 内部网络靶机进行模拟攻击； 4) 使用流量发生器和模拟攻击工具构造组合型攻击流量和报文,对 IDC 内部网络靶机进行模拟攻击； 5) 查看 IDC 内安全防护产品的攻击事件记录及处理情况,在 IDC 内部网络靶机处使用流量分析仪进行抓包分析
预期结果： 1) IDC 能够对已知安全漏洞攻击流量和攻击报文进行检测； 2) IDC 能够对疑似安全漏洞攻击行为进行研判和预警； 3) IDC 能够对组合型攻击流量和攻击报文进行检测和告警； 4) IDC 能够对攻击源进行溯源并记录操作行为； 5) IDC 能够解析 IPv4/IPv6 报文,通过 IP 5 元组、攻击数据包类型、攻击报文关键字、攻击流量等对已知安全漏洞攻击进行阻断
判定原则： 达到以上预期结果,则通过,否则不通过

表 28 网络入侵防范 DDoS 攻击防范测试方法

测试编号:IDC-第 2 级-网络安全-网络入侵防范-02
测试项目:6.2.2.3 b)IDC 具备对 DDoS 攻击的防范能力,包括以下能力:1)能够对常见 DDoS 攻击(如 ARP/ND 泛洪攻击、同步泛洪攻击、UDP 泛洪攻击、ICMP 泛洪攻击等)进行检测和告警;2)能够对 Web 应用层 DDoS 攻击(如 CC 攻击)进行检测和告警;3)能够对 DDoS 攻击源或僵尸机记录攻击行为;4)能够通过解析 IPv4/IPv6 报文,基于 IP 5 元组、网络应用种类、协议类型、协议标签等进行包过滤、阈值限制、重定向等手段清洗 DDoS 攻击流量,DDoS 攻击防护能力覆盖 IDC 网络出口带宽
测试步骤: 1) 访谈网络安全管理人员,查看网络设计文档、网络安全策略、设备配置记录、日志记录等,查看 IDC 相关安全防护设备的策略配置和历史事件记录; 2) 使用流量发生器和模拟攻击工具构造基于 TCP、UDP、ICMP 等多种协议的 DDoS 攻击流量,对 IDC 内部网络靶机进行模拟攻击; 3) 使用流量发生器和模拟攻击工具构造 CC 攻击流量,对 IDC 内部网络靶机进行模拟攻击; 4) 查看 IDC 内安全防护产品的攻击事件记录及处理情况,在 IDC 内部网络靶机处使用流量分析仪进行抓包分析
预期结果: 1) IDC 能够对常见 DDoS 攻击(如 ARP/ND Flood、TCP SYN Flood、UDP Flood、ICMP Flood 等)进行检测和告警; 2) IDC 能够对 Web 应用层 DDoS 攻击(如 CC 攻击)进行检测和告警; 3) IDC 能够对 DDoS 攻击源或僵尸机溯源并记录攻击行为; 4) IDC 能够通过解析 IPv4/IPv6 报文,基于 IP 5 元组、网络应用种类、协议类型、协议标签等进行包过滤、阈值限制、重定向等手段清洗 DDoS 攻击流量
判定原则: 达到以上预期结果,则通过,否则不通过

表 29 网络入侵防范防御测试方法

测试编号:IDC-第 2 级-网络安全-网络入侵防范-03
测试项目:6.2.2.3 c)IDC 能够检测并防御以下攻击行为:端口扫描、暴力破解攻击、木马后门攻击、缓冲区溢出攻击、ARP/ND 欺骗攻击、IP 碎片攻击、网络蠕虫攻击等
测试步骤: 1) 访谈网络安全管理人员,查看网络安全策略、设备配置记录、日志记录等,查看 IDC 相关安全防护设备的策略配置和历史事件记录; 2) 使用漏洞扫描器和模拟攻击工具对 IDC 内部网络靶机进行端口扫描和模拟字典攻击; 3) 使用模拟攻击工具对 IDC 内部网络靶机进行服务账号口令等暴力破解攻击; 4) 使用模拟攻击工具向 IDC 内部网络靶机投放具有木马和蠕虫特征的病毒样本; 5) 使用流量发生器构造缓冲区溢出和 IP 碎片攻击流量,对 IDC 内部网络靶机进行模拟攻击; 6) 查看 IDC 内安全防护产品的攻击事件记录及处理情况,在 IDC 内部网络靶机处使用流量分析仪进行抓包分析
预期结果: IDC 能够对端口扫描、暴力破解、攻击木马后门攻击、缓冲区溢出攻击、IP 碎片攻击、ARP/ND 欺骗攻击、网络蠕虫攻击等常见攻击进行检测、告警和防御
判定原则: 达到以上预期结果,则通过,否则不通过

7.2.2.4 网络安全监测

第 2 级网络安全监测除按照 7.1.1.4 的测试方法进行测试之外,还应按照表 30~表 33 进行测试。

表 30 网络安全监测资源使用测试方法

测试编号:IDC-第 2 级-网络安全-网络安全监测-01
测试项目:6.2.2.4 a)对 IDC 自身业务中的重要主机进行监视,包括监视主机的 CPU、硬盘、内存、网络等资源的使用情况
测试步骤: 1) 访谈网络运维人员,查看设备维护记录、故障告警记录、日志文件资料等,查看对重要主机设备的状态监控设计; 2) 检查 IDC 监测平台是否对自身业务中重要主机设备进行性能及运行状态信息监测,监测内容包括设备的 CPU、硬盘、内存、网络等资源
预期结果: IDC 能够对自身业务中重要主机设备进行性能及运行状态信息监测,包括设备的 CPU、硬盘、内存、网络等资源的使用情况
判定原则: 达到以上预期结果,则通过,否则不通过

表 31 网络安全监测数据包监测测试方法

测试编号:IDC-第 2 级-网络安全-网络安全监测-02
测试项目:6.2.2.4 b)对于目的地址为 IDC 网络内地址的数据包,安全域边界具有有效的攻击识别和监测能力,具有对于异常数据流量的识别和处理能力
测试步骤: 1) 访谈网络运维和安全管理人员,查看网络设计文档、网络安全策略、运维管理制度、设备配置文档等,查看 IDC 在安全域边界处的流量监测设备配置和策略; 2) 使用流量发生器向 IDC 安全域内构造多种异常流量; 3) 在 IDC 安全域边界流量监测系统处查看监测事件日志,在安全域内被模拟攻击设备处使用流量分析仪进行抓包分析
预期结果: IDC 在安全域边界处具有对异常数据流量的有效识别和监测能力
判定原则: 达到以上预期结果,则通过,否则不通过

表 32 网络安全监测流量过滤测试方法

测试编号:IDC-第 2 级-网络安全-网络安全监测-03
测试项目:6.2.2.4 c)IDC 出入口路由器具备 IPv4/IPv6 源地址验证和虚假源地址流量过滤功能

测试步骤： 1) 访谈网络运维和安全管理人員，查看网络设计文档、网络安全策略、设备配置记录、监测报告等，查看 IDC 的虚假源地址过滤功能部署和相应指标； 2) 检查 IDC 出口网络设备的配置，是否配置有虚假源地址过滤功能； 3) 使用流量发生器在 IDC 内构造虚假源地址上行流量，在流量接收设备侧实时记录虚假源地址流量接收情况
预期结果： IDC 能够对虚假源地址流量进行过滤
判定原则： 达到以上预期结果，则通过，否则不通过

表 33 网络安全监测采集转发测试方法

测试编号:IDC-第 2 级-网络安全-网络安全监测-04
测试项目:6.2.2.4 d)IDC 出入口路由器具备流量元数据采集和转发功能，采集格式支持 NetFlow(V5 及以上)、Net-Stream(V5 及以上)或 sFlow(V4 及以上)，采样率不低于千分之一
测试步骤： 1) 访谈网络运维人員，查看网络设计文档、设备配置记录、日志文件资料等，查看 IDC 出入口路由器是否具有流量元数据采集和转发功能的设计； 2) 检查 IDC 出入口路由器是否配有流量元数据采集和转发功能，检查采集格式； 3) 检查 IDC 出入口路由器流量元数据采样率
预期结果： 1) IDC 出入口路由器配有流量元数据采集和转发功能； 2) IDC 出入口路由器采集格式支持 NetFlow(V5 及以上)或 NetStream(V5 及以上)或 sFlow(V4 及以上)； 3) IDC 出入口路由器流量采样率不低于千分之一
判定原则： 达到以上预期结果，则通过，否则不通过

7.2.2.5 网络保护与恢复

第 2 级网络网络保护与恢复的测试方法见表 34～表 37。

表 34 网络保护与恢复灾难恢复能力测试方法

测试编号:IDC-第 2 级-网络安全-网络保护与恢复-01
测试项目:6.2.2.5 a)IDC 具备一定的抗灾难以及灾难恢复能力，自身重要服务器、重要部件、重要数据库采用本地双机备份的方式进行容灾保护
测试步骤： 1) 访谈网络运维人員，查看网络设计文档、设备配置文档、故障告警记录、应急演练记录等，查看 IDC 自身重要设备的冗余情况； 2) 查看 IDC 自身重要设备的部件(或板卡、模块等)配置和主备使用情况； 3) 查看应急演练等记录中 IDC 自身重要设备及重要部件的主备切换情况，核实其主备冗余保护效果



预期结果： IDC 自身重要设备采用了本地双机备份措施
判定原则： 达到以上预期结果，则通过，否则不通过

表 35 网络保护与恢复灾难恢复时间测试方法

测试编号：IDC-第 2 级-网络安全-网络保护与恢复-02
测试项目：6.2.2.5 b)IDC 网络灾难恢复时间满足国家或行业对应急预案的相关要求
测试步骤： 1) 访谈网络运维人员和安全管理人员，查看网络安全策略、运维管理制度、灾难应急预案等，查看对于不同网络灾难恢复时间的相关要求； 2) 查看应急演练等记录中 IDC 网络灾难恢复时间
预期结果： 1) IDC 应急预案对不同的网络灾难分别有不同的恢复时间要求； 2) IDC 网络灾难恢复时间能够满足国家或行业应急预案相关要求
判定原则： 达到以上预期结果，则通过，否则不通过

表 36 网络保护与恢复数据本地备份测试方法

测试编号：IDC-第 2 级-网络安全-网络保护与恢复-03
测试项目：6.2.2.5 c)IDC 重要信息数据提供本地异机备份
测试步骤： 1) 访谈网络运维人员和安全管理人员，查看数据备份要求、安全策略、灾难应急预案、数据备份记录等，查看 IDC 重要数据的备份方式； 2) 查看 IDC 重要数据（如业务数据、设备配置数据、性能数据、告警数据等）是否有本地数据备份； 3) 通过加载备份数据等方式验证其有效性及恢复能力是否均符合要求
预期结果： IDC 重要数据（如业务数据、设备配置数据、性能数据、告警数据等）本地备份与设计/验收文档一致
判定原则： 达到以上预期结果，则通过，否则不通过

表 37 网络保护与恢复能力测试方法

测试编号：IDC-第 2 级-网络安全-网络保护与恢复-04
测试项目：6.2.2.5 d)IDC 的数据备份范围和时间间隔、数据恢复能力符合国家或行业对应急预案的相关要求

测试步骤： 访谈网络运维人员和安全管理人员，查看数据备份要求、安全策略、灾难应急预案、数据备份记录等，查看 IDC 重要信息数据的备份范围、时间间隔
预期结果： IDC 的数据备份范围和时间间隔、数据恢复能力符合国家或行业应急预案的相关要求
判定原则： 达到以上预期结果，则通过，否则不通过

7.2.2.6 网络设备防护

第 2 级网络设备防护除按照 7.1.1.5 的测试方法进行测试之外，还应按照表 38～表 41 进行测试。

表 38 网络设备防护日志管理测试方法

测试编号：IDC-第 2 级-网络安全-网络设备防护-01
测试项目：6.2.2.6 a) IDC 网络宜配置中央日志服务器，对日志进行统一管理、分析处理
测试步骤： 访谈网络运维人员，查看 IDC 网络设备日志记录和配置情况等
预期结果： IDC 网络配置中央日志服务器，对日志进行统一管理、分析处理
判定原则： 达到以上预期结果，则通过，否则不通过

表 39 网络设备防护日志内容测试方法

测试编号：IDC-第 2 级-网络安全-网络设备防护-02
测试项目：6.2.2.6 b) 对 IDC 网络系统中的关键网络设备运行状况、网络流量、用户行为等进行日志记录，并定期对日志进行安全审计，形成相关的审计文档
测试步骤： 访谈网络运维人员，查看 IDC 关键网络设备日志记录等
预期结果： 1) IDC 关键网络设备的日志记录包括运行状况、网络流量、用户行为等内容； 2) 定期对日志进行安全审计，形成了相关的审计文档
判定原则： 达到以上预期结果，则通过，否则不通过



表 40 网络设备防护日志审计测试方法

测试编号:IDC-第 2 级-网络安全-网络设备防护-03
测试项目:6.2.2.6 e)IDC 网络边界设备的安全日志在本地或外部设备上记录、输出、存储,并及时、定期审计安全域边界安全防护设备的日志,日志审计范围覆盖设备自身操作维护记录,以及设备对外部发起行为的记录,形成相关的审计文档
测试步骤: 1) 访谈网络运维和安全管理人,查看日志系统设计文档、网络安全策略、设备配置记录、日志和审计文件资料等,查看 IDC 网络边界设备日志和审计的安全机制; 2) 查看日志和审计记录的记录、输出、存储方式; 3) 查看审计记录的内容和形成时间
预期结果: 1) IDC 网络边界设备的日志在本地的记录、输出、存储符合安全管控策略要求; 2) IDC 网络边界设备的日志在外部设备的记录、输出、存储符合安全管控策略要求; 3) 定期审计日志并形成审计文档; 4) 日志审计范围覆盖了网络设备自身操作维护记录、设备对外部发起行为的记录等
判定原则: 达到以上预期结果,则通过,否则不通过

表 41 网络设备防护审计记录测试方法

测试编号:IDC-第 2 级-网络安全-网络设备防护-04
测试项目:6.2.2.6 e)IDC 网络设备审计记录包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息
测试步骤: 访谈网络运维人,查看 IDC 网络的审计记录等
预期结果: IDC 网络设备审计记录包括了事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息
判定原则: 达到以上预期结果,则通过,否则不通过

7.2.3 主机安全

测试方法与 7.1.2 相同。

7.2.4 中间件安全

第 2 级中间件安全除按照 7.1.3 的测试方法进行测试之外,还应按照表 42~表 43 进行测试。

表 42 中间件安全协议配置测试方法

测试编号:IDC-第 2 级-中间件安全- 01
测试项目:6.2.4 a)IDC 自身业务所使用的中间件进行协议级的配置时应禁用中间件的不必要的 HTTP 方法,例如 PUT,TRACE,DELETE 等,若启用了 HTTPS 则应禁用 HTTP
测试步骤: 1) 访谈安全管理人员,查看网络安全策略、设备配置记录等,查看 IDC 自身业务所使用的中间件的协议级配置; 2) 使用流量发生器构造基于 HTTP 协议的 PUT、TRACE、DELETE 等行为报文,向安装有中间件的 IDC 自身业务主机进行发送; 3) 对于启用了 HTTPS 的 Web 系统,使用流量发生器构造基于 HTTP 协议的 GET 等行为报文,向安装有中间件的 IDC 自身业务主机进行发送; 4) 在安装有中间件的 IDC 自身业务主机处使用流量分析仪进行抓包分析
预期结果: 1) IDC 自身业务所使用的中间件禁用了不必要的 HTTP 方法,例如 PUT,TRACE,DELETE 等; 2) 启用了 HTTPS 的通信阶段禁用了 HTTP
判定原则: 达到以上预期结果,则通过,否则不通过

表 43 中间件安全语言安全测试方法

测试编号:IDC-第 2 级-中间件安全- 02
测试项目:6.2.4 b)IDC 自身业务所使用的中间件宜启用必要的语言安全设置,例如 PHP 语言安全设置,JAVA 语言安全设置
测试步骤: 访谈安全管理人员,查看网络安全策略、设备配置记录等,查看 IDC 自身业务所使用的中间件的语言安全配置,包括 PHP cookie 加密配置、JVM 缓存防溢出配置等
预期结果: IDC 自身业务所使用的中间件启用了必要的语言安全设置,例如 PHP 语言安全设置,JAVA 语言安全设置
判定原则: 达到以上预期结果,则通过,否则不通过。

7.2.5 物理环境安全

第 2 级物理环境安全除按照 7.1.4 的测试方法进行测试之外,还应按照表 44 进行测试。

表 44 物理环境安全 2 级测试方法

测试编号:IDC-第 2 级-物理环境安全-01
测试项目:6.2.5 应满足第 1 级和 GB/T 22239—2019 中第二级的安全物理环境要求

测试步骤： 1) 访谈物理环境管理人员，查看物理环境设计文档、管理制度、维护记录等，查看其是否符合 GB/T 22239—2019 中第二级的相关要求； 2) 现场检查 IDC 所处的物理环境
预期结果： IDC 物理环境的安全要求符合 GB/T 22239—2019 中第二级的相关要求
判定原则： 达到以上预期结果，则通过，否则不通过

7.2.6 管理安全

7.2.6.1 安全管理要求

第 2 级安全管理要求除按照 7.1.5 的测试方法进行测试之外，还应按照表 45～表 48 进行测试。

表 45 安全管理要求 2 级通用测试方法

测试编号：IDC-第 2 级-管理安全-安全管理-01
测试项目：6.2.6.1 满足 GB/T 22239—2019 中第二级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求
测试步骤： 访谈网络安全管理人员，查看与网络安全管理相关的材料等，查看其是否符合 GB/T 22239—2019 中第二级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求
预期结果： IDC 管理安全要求符合 GB/T 22239—2019 中第二级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求
判定原则： 达到以上预期结果，则通过，否则不通过

表 46 安全管理要求介质管理测试方法

测试编号：IDC-第 2 级-管理安全-安全管理-02
测试项目：6.2.6.1 a)IDC 有介质存取、验证、转存、销毁管理制度，确保备份数据授权访问
测试步骤： 访谈网络安全管理人员，查看网络安全管理制度、存储介质管理制度、介质操作记录等
预期结果： IDC 具备介质存取、验证、转储、销毁管理制度
判定原则： 达到以上预期结果，则通过，否则不通过

表 47 安全管理要求数据有效性测试方法

测试编号:IDC-第 2 级-管理安全-安全管理-03
测试项目:6.2.6.1 b)IDC 按介质特性对备份数据进行定期的有效性验证
测试步骤: 访谈网络安全管理人员,查看网络安全管理制度、运行维护记录等
预期结果: IDC 按介质特性对备份数据进行定期的有效性验证
判定原则: 达到以上预期结果,则通过,否则不通过

表 48 安全管理要求灾备管理制度测试方法

测试编号:IDC-第 2 级-管理安全-安全管理-04
测试项目:6.2.6.1 c)IDC 有相关服务器设备的灾难备份及恢复的管理制度
测试步骤: 访谈网络安全管理人员,查看网络安全管理制度、运行维护记录、应急预案等
预期结果: IDC 具备相关服务器设备的灾难备份及恢复的管理制度
判定原则: 达到以上预期结果,则通过,否则不通过

7.2.6.2 风险评估要求

第 2 级风险评估要求的测试方法见表 49～表 50。

表 49 风险评估 2 级时间范围测试方法

测试编号:IDC-第 2 级-管理安全-风险评估要求-01
测试项目:6.2.6.2 a)IDC 及其所属各类设备、系统根据安全防护相关规定定期进行安全风险评估(至少每两年一次),风险评估范围与 IDC 安全防护范围一致
测试步骤: 1) 访谈网络安全管理人员,查看风险评估报告,查看 IDC 及其所属各类设备、系统的风险评估情况; 2) 检查网络安全风险评估是否符合的要求; 3) 检查风险评估周期是否符合要求; 4) 检查风险评估范围是否与 IDC 安全防护范围相一致
预期结果: 1) IDC 及其所属各类设备、系统定期进行安全风险评估; 2) 安全风险评估的周期满足至少每两年一次; 3) 安全风险评估范围与 IDC 安全防护范围一致
判定原则: 达到以上预期结果,则通过,否则不通过

表 50 风险评估内容覆盖测试方法

测试编号:IDC-第 2 级-管理安全-风险评估要求-02
测试项目:6.2.6.2 b)IDC 安全风险评估至少覆盖业务安全、网络安全、主机安全、中间件安全、物理环境安全等相关技术风险和人员安全、运维安全等相关管理风险,至少包含 IDC 相关资产、脆弱性、威胁、安全措施、风险分析等要素和内容,并根据评估结果制定相应的风险处理计划
测试步骤: 1) 访谈网络安全管理人员,查看风险评估报告、风险处理计划和报告、安全加固和升级记录等; 2) 检查 IDC 安全风险评估的覆盖范围; 3) 检查风险评估的要素和内容; 4) 检查是否根据评估结果制定相应的风险处理计划
预期结果: 1) IDC 安全风险评估至少覆盖网络安全、设备安全、物理环境安全等相关技术风险和人员安全、运维安全等相关管理风险; 2) IDC 安全风险评估至少包含相关资产、脆弱性、威胁、安全措施、风险分析等要素和内容,同时包含了与这些要素密切相关的属性,如业务、资产价值、安全需求和安全事件等; 3) 根据评估结果制定了相应的风险处理计划
判定原则: 达到以上预期结果,则通过,否则不通过

7.2.6.3 灾难恢复预案

第 2 级灾难恢复预案的测试方法见表 51~表 53。

表 51 灾难恢复预案管理制度测试方法

测试编号:IDC-第 2 级-管理安全-灾难恢复预案-01
测试项目:6.2.6.3 a)IDC 制定完整的灾难恢复预案及对应管理制度
测试步骤: 访谈网络安全管理人员,查看网络安全管理制度、网络灾难恢复预案等
预期结果: 1) IDC 灾难恢复预案符合的相关要求; 2) 灾难恢复预案与设计/验收文档一致,有明确的作用范围,指定了灾难恢复的目标,包含灾难恢复的整个过程; 3) 灾难恢复预案有评审报告,通过决策层的审核和批准,确定为正式执行文件
判定原则: 达到以上预期结果,则通过,否则不通过

表 52 灾难恢复预案培训测试方法

测试编号:IDC-第 2 级-管理安全-灾难恢复预案-02
测试项目:6.2.6.3 b)IDC 有灾难恢复预案的教育和培训(至少每半年一次),相关人员应了解灾难恢复预案并具有对灾难恢复预案进行实际操作的能力
测试步骤: 1) 访谈网络安全管理人员,查看网络安全管理制度、预案教育培训记录等; 2) 访谈培训人员,了解灾难预案培训实际效果
预期结果: 1) IDC 至少每半年进行一次灾难恢复预案的教育培训; 2) 相关人员了解灾难恢复预案并具有对灾难恢复预案进行实际操作的能力
判定原则: 达到以上预期结果,则通过,否则不通过

表 53 灾难恢复预案演练测试方法

测试编号:IDC-第 2 级-管理安全-灾难恢复预案-03
测试项目:6.2.6.3 c)IDC 有灾难恢复预案的演练(至少每年一次),并根据演练结果对灾难恢复预案进行修正
测试步骤: 访谈网络安全管理人员,查看网络安全管理制度、灾难恢复预案、应急演练记录等
预期结果: 1) IDC 至少每年进行一次灾难恢复预案的演练; 2) 灾难恢复预案根据演练结果进行修订
判定原则: 达到以上预期结果,则通过,否则不通过

7.3 第 3 级要求

7.3.1 业务安全

测试方法与 7.2.1 相同。

7.3.2 网络安全

7.3.2.1 网络结构

第 3 级网络结果除按照 7.2.2.1 的测试方法进行测试之外,还应按照表 54 进行测试。

表 54 网络结构分开部署测试方法

测试编号:IDC-第 3 级-网络安全-网络结构安全-01
测试项目:6.3.2.1 IDC 的 Web 服务器、后台数据库应分开部署在不同物理主机上

测试步骤： 1) 访谈网络运维和安全管理人员，查看网络设计/验收文档、网络拓扑文档、网络安全策略、运维管理制度、设备配置文档等； 2) 查看 Web 服务器和数据库服务器的部署位置和之间的连接情况
预期结果： IDC 的 Web 服务器、后台数据库分开部署在不同物理主机上
判定原则： 达到以上预期结果，则通过，否则不通过

7.3.2.2 网络管理

第 3 级网络管理除按照 7.2.2.2 的测试方法进行测试之外，还应按照表 55 进行测试。

表 55 网络管理安全域访问测试方法

测试编号：IDC-第 3 级-网络安全-网络管理-01
测试项目：6.3.2.2 安全域之间的 IP 网络边界设备应启用接入访问控制策略，应依据不同安全域互相访问需求对包括源 IP 地址、端口号等在内的控制项进行限制，避免开放过长 IP 地址段及过多端口
测试步骤： 访谈网络运维和安全管理人员，查看网络设计文档、网络安全策略、运维管理制度、设备配置文档等，查看 IDC 不同安全域之间的 IP 网络边界设备的访问控制策略
预期结果： 安全域之间的 IP 网络边界设备启用了接入访问控制策略，依据不同安全域互相访问需求对控制项进行了限制
判定原则： 达到以上预期结果，则通过，否则不通过

7.3.2.3 网络入侵防范

第 3 级网络入侵防范除按照 7.2.2.3 的测试方法进行测试之外，还应按照表 56～表 58 进行测试。

表 56 网络入侵防范攻击记录测试方法

测试编号：IDC-第 3 级-网络安全-网络入侵防范-01
测试项目：6.3.2.3 a) 当检测到攻击行为时，记录攻击源 IP、攻击类型、攻击目的、攻击时间，在发生严重入侵事件时应能够实时报警
测试步骤： 1) 访谈网络安全管理人员，查看网络安全策略、设备配置记录等，查看 IDC 相关安全防护设备的历史事件记录和告警记录； 2) 使用流量发生器和模拟攻击工具构造多种流量和报文，对 IDC 内部网络靶机进行模拟攻击； 3) 查看 IDC 内安全防护产品的攻击事件记录及处理情况，在 IDC 内部网络靶机处使用流量分析仪进行抓包分析

预期结果： 1) IDC 安全防护产品检测到攻击时能够记录攻击源 IP、攻击类型、攻击目的、攻击时间； 2) IDC 在发生严重入侵事件时能够实时报警
判定原则： 达到以上预期结果，则通过，否则不通过

表 57 网络入侵防范恶意代码测试方法

测试编号:IDC-第 3 级-网络安全-网络入侵防范-02
测试项目:6.3.2.3 b)在 IDC 网络边界处对恶意代码进行检测和处理,并及时对检测系统进行更新
测试步骤： 1) 访谈网络安全管理人员,查看网络设计文档、网络安全策略、设备配置记录等,查看 IDC 网络边界处安全防护设备的策略配置、事件记录和操作日志； 2) 使用模拟攻击工具从互联网向 IDC 内部网络靶机发送具有恶意代码特征的文件； 3) 查看 IDC 网络边界处安全防护产品的恶意代码检测记录及处理情况,在 IDC 内部网络靶机处使用流量分析仪进行抓包分析
预期结果： 1) IDC 能够在网络边界处对恶意代码进行检测和处理； 2) IDC 能够及时对检测系统进行更新
判定原则： 达到以上预期结果，则通过，否则不通过

表 58 网络入侵防范恶意代码软件测试方法

测试编号:IDC-第 3 级-网络安全-网络入侵防范-03
测试项目:6.3.2.3 c)IDC 对防恶意代码软件进行统一管理
测试步骤： 1) 访谈安全管理人员,查看网络安全策略、设备配置文档等,查看使用相同防恶意代码软件的主机及网络设备的恶意代码库版本； 2) 查看主机和网络设备防恶意代码软件的升级方式及升级地址； 3) 查看各主机及网络设备恶意代码库升级时间
预期结果： 1) IDC 内使用相同防恶意代码软件的主机及网络设备的恶意代码库版本一致； 2) IDC 内相同防恶意代码软件的升级方式相同,若使用内网在线升级,则升级地址相同； 3) IDC 内使用相同防恶意代码软件的主机及网络设备的恶意代码库升级时间基本一致
判定原则： 达到以上预期结果，则通过，否则不通过

7.3.2.4 网络安全监测

第 3 级网络安全监测除按照 7.2.2.4 的测试方法进行测试之外,还应按照表 59～表 61 进行测试。

表 59 网络安全监测僵尸木马蠕虫监测测试方法

测试编号:IDC-第 3 级-网络安全-网络安全监测-01
测试项目:6.3.2.4 a)IDC 具有对僵尸网络、木马和蠕虫的监测能力,在 IDC 出入口对进出流量进行监测,在 IDC 内部对内部流量进行监测。包括以下能力:1)能够对已知僵尸网络、木马和蠕虫病毒进行监测和告警;2)能够对压缩流量和嵌入型僵尸网络和木马进行监测和告警;3)能够对僵尸网络和木马控制端进行溯源并记录操作行为;4)能够对疑似僵尸网络、木马和蠕虫病毒进行预警;5)能够对 IDC 机房服务器的 Web 网站进行挂马扫描;6)能够对 IDC 机房服务器的 IPv4/IPv6 地址进行系统漏洞扫描;7)具备基于网络行为、样本特征和恶意 URL 的僵尸网络、木马和蠕虫病毒库
测试步骤: 1) 访谈网络安全管理人员,查看网络设计文档、网络安全策略、设备配置记录等,查看 IDC 僵尸蠕虫监测系统的策略配置、事件记录和操作日志,查看网页挂马扫描器的策略配置、事件记录和操作日志; 2) 使用流量发生器和模拟攻击工具构造已知的僵尸蠕虫网络行为或样本特征,从互联网向 IDC 内部网络靶机进行发送; 3) 使用流量发生器和模拟攻击工具构造监测系统特征库中没有的疑似僵尸蠕虫网络行为或样本特征,从互联网向 IDC 内部网络靶机进行发送; 4) 使用流量发生器和模拟攻击工具构造已知的僵尸蠕虫压缩流量或嵌入型样本特征,从互联网向 IDC 内部网络靶机进行发送; 5) 将模拟僵尸蠕虫控制端 URL 添加入监测系统特征库中,使用流量发生器和模拟攻击工具构造多种报文和流量,从互联网向 IDC 内部网络靶机进行发送; 6) 在 IDC 内部部署挂有木马的 Web 测试系统,使用 IDC 网页挂马扫描器对其进行扫描; 7) 查看 IDC 僵尸蠕虫监测系统的事件记录及处理情况,在 IDC 内部网络靶机处使用流量分析仪进行抓包分析; 8) 查看 IDC 网页挂马扫描器的扫描情况
预期结果: 1) IDC 能够对已知僵尸网络、木马和蠕虫病毒进行监测和告警; 2) IDC 能够对疑似僵尸网络、木马和蠕虫病毒进行预警; 3) IDC 能够对压缩流量和嵌入型僵尸网络和木马进行监测和告警; 4) IDC 具备基于网络行为、样本特征和恶意 URL 的僵尸网络、木马和蠕虫病毒库; 5) IDC 能够对僵尸网络和木马控制端进行溯源并记录操作行为; 6) IDC 能够对 IDC 机房服务器的 Web 网站进行挂马扫描
判定原则: 达到以上预期结果,则通过,否则不通过

表 60 网络安全监测数据处理测试方法

测试编号:IDC-第 3 级-网络安全-网络安全监测-02
测试项目:6.3.2.4 b)IDC 具有对不同种类业务相关数据进行监测、统计、控制、过滤的功能
测试步骤: 1) 访谈网络运维人员,查看网络管理系统设计文档、设备配置记录等,查看对不同业务数据的监测、统计和处理记录; 2) 使用流量发生器模拟某种业务流量(如,HTTP、FTP、Telnet、SMTP、POP3、SIP 等)在 IDC 内传送,查看管理系统的实时记录情况



预期结果： 1) IDC建有对网络业务数据进行安全管理的技术手段； 2) IDC具有对网络业务相关数据进行监测、统计、控制、过滤的功能
判定原则： 达到以上预期结果，则通过，否则不通过

表 61 网络安全监测操作行为测试方法

测试编号:IDC-第 3 级-网络安全-网络安全监测-03
测试项目:6.3.2.4 c)宜对 IDC 管理运维人员的设备系统访问等操作行为进行监控和审计
测试步骤： 访谈网络运维人员，查看网络管理系统设备配置记录、日志、审计信息等，查看对不同管理运维人员的操作行为记录
预期结果： IDC 对管理运维人员的设备系统访问等操作行为有监控记录，且记录信息定期进行审计；
判定原则： 达到以上预期结果，则通过，否则不通过

7.3.2.5 网络保护与恢复

第 3 级网络保护与恢复除按照 7.2.2.5 的测试方法进行测试之外，还应按照表 62～表 65 进行测试。

表 62 网络保护与恢复容灾保护测试方法

测试编号:IDC-第 3 级-网络安全-网络保护与恢复-01
测试项目:6.3.2.5 a)IDC 具备一定的抗灾难以及灾难恢复能力,重要服务器、重要部件、重要数据库应当采用异址(同城不同地点的机房或异地)方式进行容灾保护
测试步骤： 1) 访谈网络运维人员，查看网络设计文档、设备配置文档、故障告警记录、应急演练记录等，查看 IDC 自身重要设备的冗余情况； 2) 查看 IDC 自身重要设备的部件(或板卡、模块等)配置和主备使用情况； 3) 查看应急演练等记录中 IDC 自身重要设备及重要部件的主备切换情况，核实其主备冗余保护效果
预期结果： IDC 自身重要设备采用了异址(同城不同地点的机房或异地)备份措施
判定原则： 达到以上预期结果，则通过，否则不通过

表 63 网络保护与恢复网络冗余链路测试方法

测试编号:IDC-第 3 级-网络安全-网络保护与恢复-02
测试项目:6.3.2.5 b)IDC 与互联网之间具备冗余链路

测试步骤： 1) 访谈网络运维人员，查看网络设计文档、网络拓扑文档、故障告警记录、日志记录等，查看 IDC 与互联网间链路部署情况； 2) 查看 IDC 互联网出口节点的配置信息，查看节点间链路冗余保护情况，检查其是否至少保有两条不同物理路径的连接
预期结果： IDC 与互联网之间具备冗余链路
判定原则： 达到以上预期结果，则通过，否则不通过

表 64 网络保护与恢复设备冗余链路测试方法

测试编号：IDC-第 3 级-网络安全-网络保护与恢复-03
测试项目：6.3.2.5 c)IDC 为网络中关键设备之间提供多条物理链路(如 Web 服务器设备与数据库服务器设备之间)
测试步骤： 1) 访谈网络运维人员，查看网络设计文档、网络拓扑文档、故障告警记录、日志记录等，查看网络中关键设备之间链路部署情况； 2) 查看 IDC 中关键设备的配置信息，查看设备间链路冗余保护情况，检查其是否至少保有两条不同物理路径的连接
预期结果： IDC 网络中关键设备之间连接多条物理链路
判定原则： 达到以上预期结果，则通过，否则不通过

表 65 网络保护与恢复数据异址备份测试方法

测试编号：IDC-第 3 级-网络安全-网络保护与恢复-04
测试项目：6.3.2.5 d)IDC 为重要信息数据提供异址备份(同城不同地点的机房或异地)
测试步骤： 1) 访谈网络运维和安全管理人員，查看数据备份要求、安全策略、灾难应急预案、数据备份记录等，查看 IDC 的数据备份机制； 2) 查看 IDC 相关关键数据(如业务数据、设备配置数据、性能数据、告警数据等)是否具有异址数据备份； 3) 查看异址数据备份的备份范围、时间间隔，加载备份数据，测试备份数据的恢复能力
预期结果： 1) IDC 重要数据提供了异址备份(同城不同地点的机房或异地)； 2) 异址备份数据的备份范围、时间间隔符合要求，具有数据恢复能力
判定原则： 达到以上预期结果，则通过，否则不通过



7.3.2.6 网络设备防护

第 3 级网络设备防护除按照 7.2.2.6 的测试方法进行测试之外,还应按照表 66 进行测试。

表 66 网络设备防护口令更新周期测试方法

测试编号:IDC-第 3 级-网络安全-网络设备防护-01
测试项目:6.3.2.6 IDC 网络设备账号口令更新周期应不大于 60 天。 测试步骤: 访谈网络运维和安全管理人员,查看网络安全策略、账号管理和权限分配记录、设备配置文件、安全检查记录等,查看网络设备操作系统的账号口令更新情况
预期结果: IDC 网络设备账号口令更新周期不大于 60 天
判定原则: 达到以上预期结果,则通过,否则不通过

7.3.3 主机安全

第 3 级主机安全除按照 7.2.3 的测试方法进行测试之外,还应按照表 67~表 71 进行测试。

表 67 主机安全口令更新周期测试方法

测试编号:IDC-第 3 级-主机安全-01
测试项目:6.3.3 a)IDC 通用主机操作系统和数据库系统管理用户口令更新周期不大于 60 d
测试步骤: 访谈网络运维和安全管理人员,查看网络安全策略、账号管理和权限分配记录、设备配置文件、安全检查记录等,查看通用主机操作系统和数据库系统管理用户的账号口令更新情况
预期结果: IDC 通用主机操作系统和数据库系统管理用户口令更新周期不大于 60 d
判定原则: 达到以上预期结果,则通过,否则不通过

表 68 主机安全敏感标记测试方法

测试编号:IDC-第 3 级-主机安全-02
测试项目:6.3.3 b)依据安全策略严格控制用户对有敏感标记重要信息(如,配置信息、审计记录等)的操作
测试步骤: 1) 访谈网络运维和安全管理人员,查看设备安全检测报告、网络安全策略要求、日志和审计记录等,查看通用主机对重要信息资源的保护情况; 2) 查看主机对重要信息资源(如系统配置、用户信息等)设置的操作权限和相应标记; 3) 登录主机对赋予用户权限的信息资源进行操作,检查主机处理情况; 4) 登录主机对未赋予用户权限的信息资源进行操作,检查主机处理情况

预期结果： 1) 通用主机的重要信息资源均设置敏感标记和操作权限； 2) 对有敏感标记重要信息资源的操作进行了严格控制
判定原则： 达到以上预期结果，则通过，否则不通过

表 69 主机安全数据审计测试方法

测试编号:IDC-第 3 级-主机安全-03
测试项目:6.3.3 c)能够根据记录数据进行分析,并生成审计报表
测试步骤： 访谈网络运维和安全管理人员,查看主机设备安全检测报告、网络安全策略要求、日志和审计记录等
预期结果： IDC 主机设备能够根据记录数据进行分析,并生成审计报表
判定原则： 达到以上预期结果，则通过，否则不通过

表 70 主机安全审计保护测试方法

测试编号:IDC-第 3 级-主机安全-04
测试项目:6.3.3 d)保护审计进程,避免受到未预期的中断
测试步骤： 1) 访谈网络运维和安全管理人员,查看主机设备安全检测报告、网络安全策略要求、日志和审计记录等,查看主机设备的审计进程保护策略； 2) 人为结束或中断审计进程,查看审计进程的恢复情况
预期结果： IDC 主机设备能够保护审计进程避免受到未预期的中断
判定原则： 达到以上预期结果，则通过，否则不通过

表 71 主机安全入侵记录测试方法

测试编号:IDC-第 3 级-主机安全-05
测试项目:6.3.3 e)能够检测到对 IDC 内主机进行入侵的行为,能够记录入侵的源 IPv4/IPv6 地址、攻击的类型、攻击的目的、攻击的时间,并在发生严重入侵事件时提供报警

测试步骤： 1) 访谈网络或主机安全管理人员，查看网络安全策略、设备配置记录等，查看 IDC 主机安全防护设备的历史事件记录 and 告警记录； 2) 使用流量发生器和模拟攻击工具构造多种流量和报文，对 IDC 内部网络靶机进行模拟攻击； 3) 查看 IDC 内主机安全防护产品的攻击事件记录及处理情况，在 IDC 内部网络靶机处使用流量分析仪进行抓包分析
预期结果： 1) IDC 主机安全防护产品检测到入侵时能够记录攻击源 IP、攻击类型、攻击目的、攻击时间； 2) IDC 在发生主机严重入侵事件时能够实时报警
判定原则： 达到以上预期结果，则通过，否则不通过

7.3.4 中间件安全

第 3 级中间件安全除按照 7.2.4 的测试方法进行测试之外，还应按照表 72 进行测试。

表 72 中间件安全自我保护技术测试方法

测试编号:IDC-第 3 级-中间件安全- 01
测试项目:6.3.4 IDC 自身业务所使用的中间件应用运行时应启动必要的自我安全保护技术
测试步骤： 访谈安全管理人员，查看网络安全策略、设备配置记录等，查看 IDC 自身业务所使用的中间件的自我安全保护技术情况
预期结果： IDC 自身业务所使用的中间件应用运行时启动了必要的自我安全保护技术
判定原则： 达到以上预期结果，则通过，否则不通过

7.3.5 物理环境安全

第 3 级物理环境安全除按照 7.2.5 的测试方法进行测试之外，还应按照表 73 进行测试。

表 73 物理环境安全 3 级测试方法

测试编号:IDC-第 3 级-物理环境安全-01
测试项目:6.3.5 应满足第 2 级和 GB/T 22239—2019 中第三级的安全物理环境要求
测试步骤： 1) 访谈物理环境管理人员，查看物理环境设计文档、管理制度、维护记录等，查看其是否符合 GB/T 22239—2019 中第三级的相关要求； 2) 现场检查 IDC 所处的物理环境
预期结果： IDC 物理环境的安全要求符合 GB/T 22239—2019 中第三级的相关要求

判定原则：
达到以上预期结果，则通过，否则不通过

7.3.6 管理安全

7.3.6.1 安全管理要求

第 3 级安全管理要求除按照 7.2.6.1 的测试方法进行测试之外，还应按照表 74 进行测试。

表 74 安全管理要求 3 级通用测试方法

测试编号：IDC-第 3 级-管理安全-01
测试项目：6.3.6.1 应满足第 2 级和 GB/T 22239—2019 中第三级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求
测试步骤： 访谈网络安全管理人员，查看与网络安全管理相关的材料等，查看其是否符合 GB/T 22239—2019 中第三级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求
预期结果： IDC 管理安全要求符合 GB/T 22239—2019 中第三级的安全管理制度、安全管理机构、安全管理人员、安全运维管理相关要求
判定原则： 达到以上预期结果，则通过，否则不通过

7.3.6.2 风险评估要求

第 3 级风险评估要求除按照 7.2.6.2 的测试方法进行测试之外，还应按照表 75 进行测试。

表 75 风险评估要求 3 级时间范围测试方法

测试编号：互联网数据中心（IDC）-第 3 级-管理安全-风险评估要求-01
测试项目：6.3.6.2 除满足第 2 级要求外，还应定期对 IDC 及其所属各类设备、系统进行安全风险评估（至少每年一次）
测试步骤： 1) 访谈网络安全管理人员，查看风险评估报告，查看 IDC 及其所属各类设备、系统的风险评估情况； 2) 检查网络安全风险评估是否符合的要求； 3) 检查风险评估周期是否符合要求
预期结果： 1) IDC 及其所属各类设备、系统定期进行安全风险评估； 2) 安全风险评估的周期满足至少每年一次
判定原则： 达到以上预期结果，则通过，否则不通过



7.3.6.3 灾难恢复预案

第 3 级灾难恢复预案除按照 7.2.6.3 的测试方法进行测试之外,还应按照表 76 进行测试。

表 76 灾难恢复预案测试方法

测试编号:IDC-第 3 级-管理安全-灾难恢复预案-01
测试项目:6.3.6.3 除满足第 2 级要求外,还应定期组织 IDC 及其所属各类设备、系统灾难恢复预案的教育培训(至少每季度一次)和演练(至少每半年一次)
测试步骤: 访谈网络安全管理人员,查看网络灾难恢复预案、预案教育培训和演练记录等
预期结果: 1) IDC 灾难恢复预案符合的相关要求; 2) 灾难恢复预案与设计/验收文档一致,有明确的作用范围,指定了灾难恢复的目标,包含灾难恢复的整个过程; 3) 灾难恢复预案有评审报告,通过决策层的审核和批准,确定为正式执行文件; 4) 至少每季度进行一次灾难恢复预案的教育培训; 5) 至少每半年进行一次灾难恢复预案的演练; 6) 灾难恢复预案的教育、培训、演练均留有记录
判定原则: 达到以上预期结果,则通过,否则不通过

7.3.6.4 安全建设管理

第 3 级安全建设管理的测试方法见表 77。

表 77 安全建设管理测试方法

测试编号:IDC-第 3 级-管理安全-安全建设管理-01
测试项目:6.3.6.4 IDC 业务实施时,客户应提交业务客户信息采集表,主要包含以下信息:系统数据分类与安全等级、系统对基础设施的依赖关系、系统要求配置的防火墙与路由器策略等
测试步骤: 访谈网络运维和安全管理人員,查看业务客户信息采集表等
预期结果: IDC 客户提交的业务客户信息采集表至少包括系统数据分类与安全等级、系统对基础设施的依赖关系、系统要求配置的防火墙与路由器策略等
判定原则: 达到以上预期结果,则通过,否则不通过

7.3.6.5 安全运维管理

第 3 级安全运维管理的测试方法见表 78~表 80。

表 78 安全运维管理规则设置测试方法

测试编号:IDC-第 3 级-管理安全-安全运维管理-01
测试项目:6.3.6.5 a)至少每六个月检查一次防火墙和路由器的规则设置(检测防火墙和路由器是否存在冲突规则、冗余规则或无效规则等)
测试步骤: 访谈网络运维和安全管理人员,查看网络安全策略、设备配置要求、运维管理制度等,查看比对防火墙和路由器的规则设置和检查记录
预期结果: 1) IDC 定期检查防火墙和路由器的规则设置; 2) 规则设置的检查周期为至少六个月一次
判定原则: 达到以上预期结果,则通过,否则不通过

表 79 安全运维管理弱点扫描测试方法

测试编号:IDC-第 3 级-管理安全-安全运维管理-02
测试项目:6.3.6.5 b)至少每三个月进行一次应用层弱点扫描,当基础设施或应用完成重大的升级或调整后,执行应用层弱点扫描
测试步骤: 访谈安全管理人员,查看网络安全策略、运维管理制度等,查看基础设施建设及验收材料和应用层弱点扫描记录
预期结果: 1) IDC 定期进行应用层弱点扫描; 2) 应用层弱点扫描周期为至少每三个月一次或当基础设施及应用完成重大升级和调整后
判定原则: 达到以上预期结果,则通过,否则不通过

表 80 安全运维管理应用层渗透测试方法

测试编号:IDC-第 3 级-管理安全-安全运维管理-03
测试项目:6.3.6.5 c)至少每年进行一次应用层渗透测试,当基础设施或应用完成重大的升级或调整后,执行应用层渗透测试
测试步骤: 访谈安全管理人员,查看网络安全策略、运维管理制度等,查看基础设施建设及验收材料和应用层渗透测试报告
预期结果: 1) IDC 定期进行应用层渗透测试; 2) 应用层渗透测试周期为至少每年一次或当基础设施及应用完成重大升级和调整后
判定原则: 达到以上预期结果,则通过,否则不通过

参 考 文 献

- [1] YD/T 2441—2013 互联网数据中心技术及分级分类标准
 - [2] 《关于加快推进互联网协议第六版(IPv6)规模部署和应用工作的通知》(中网办发〔2021〕15号)
-



